

**ĐẠI HỌC QUỐC GIA HÀ NỘI
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ**



BÁO CÁO TIẾN ĐỘ DỰ ÁN 1

MÔN HỌC: ĐIỆN TOÁN Đám MÂY

ĐỀ TÀI

**SatiBot – Quản lý và tương tác với các tài nguyên AWS
bằng ngôn ngữ tự nhiên**

Giảng viên hướng dẫn:	TS. Hoàng Xuân Tùng
Nhóm thực hiện:	Nhóm 10
Sinh viên thực hiện:	Cao Anh Minh (Trưởng nhóm) Trịnh Thiên Quang Phạm Đức Hùng Nguyễn Đức Huy
Lớp môn học:	INT3319 1

Hà Nội, Tháng 10/2026

MỤC LỤC

1	TỔNG QUAN VỀ DỰ ÁN	1
1.1	Giới thiệu chung về tính năng dự án	1
1.2	Giới thiệu người dùng của dự án	1
1.3	Cách thức và quy trình người dùng sử dụng sản phẩm để đạt mục đích	2
1.3.1	Nhóm kịch bản và quy trình quản trị Amazon EC2	2
1.3.2	Nhóm kịch bản và quy trình quản trị Amazon S3	4
1.3.3	Nhóm kịch bản và quy trình quản trị AWS IAM	5
1.3.4	Nhóm kịch bản và quy trình quản trị AWS Lambda	6
2	GIẢI PHÁP THỰC HIỆN DỰ KIẾN	9
2.1	Kiến trúc tính năng của hệ thống	9
2.2	Kiến trúc triển khai của hệ thống	11
2.2.1	Sơ đồ kiến trúc triển khai tổng thể (Mức cao)	11
2.2.2	Chi tiết Phân hệ Giao diện, Xác thực và Cửa ngõ API (Khối 1 & 2)	12
2.2.3	Chi tiết Phân hệ Xử lý Trung tâm và Trí tuệ Nhân tạo (Khối 3)	13
2.2.4	Chi tiết Phân hệ Điều phối Boto3, Quản trị Tài nguyên và Giám sát (Khối 4)	15
3	KẾ HOẠCH TRIỂN KHAI VÀ ƯỚC TÍNH NỖ LỰC	17
3.1	Bảng kế hoạch hành động và minh giải kiến trúc hệ thống	17
3.2	Phân công trách nhiệm và tổng hợp nỗ lực cá nhân	19

1. TỔNG QUAN VỀ DỰ ÁN

1.1 Giới thiệu chung về tính năng dự án

Trong bối cảnh điện toán đám mây phát triển mạnh mẽ, Amazon Web Services (AWS) đã trở thành nền tảng hạ tầng phổ biến bậc nhất hiện nay. Tuy nhiên, việc quản trị và cấu hình tài nguyên thông qua giao diện đồ họa (AWS Management Console) thường đòi hỏi người dùng phải thực hiện nhiều thao tác thủ công, điều hướng qua các bảng điều khiển phức tạp và tiềm ẩn nhiều rủi ro cấu hình sai. Ngược lại, việc sử dụng giao diện dòng lệnh (AWS CLI) hoặc các tập lệnh tự động lại đặt ra rào cản lớn về việc ghi nhớ cú pháp lệnh, định dạng tài liệu JSON cũng như quy chuẩn tham số. Đối với sinh viên, lập trình viên mới tiếp cận hạ tầng hoặc quản lý kỹ thuật, những rào cản này làm suy giảm đáng kể hiệu suất vận hành và gia tăng nguy cơ rò rỉ bảo mật hoặc phát sinh chi phí ngoài tầm kiểm soát.

Để giải quyết bài toán trên, nhóm đề xuất xây dựng SatiBot – ứng dụng web ChatOps thông minh hỗ trợ quản trị, cấu hình và giám sát các tài nguyên đám mây AWS hoàn toàn bằng ngôn ngữ tự nhiên (được tối ưu hóa cho tiếng Việt). Bằng cách kết hợp mô hình ngôn ngữ lớn (LLM) hỗ trợ cơ chế *Function Calling* cùng bộ công cụ AWS SDK (Boto3), SatiBot đóng vai trò là một trợ lý ảo DevOps trực quan. Người dùng chỉ cần gửi yêu cầu qua giao diện trò chuyện; hệ thống sẽ tự động phân tích ngữ cảnh, đối soát tính an toàn, kích hoạt các API AWS tương ứng và trả về kết quả kèm các chỉ số thống kê, liên kết bảo mật hoặc cảnh báo rủi ro một cách minh bạch và chuẩn hóa.

1.2 Giới thiệu người dùng của dự án

Hệ thống SatiBotBot được thiết kế để phục vụ 03 nhóm đối tượng người dùng mục tiêu với các nhu cầu và mức độ am hiểu kỹ thuật khác nhau:

- **Nhân viên kỹ thuật và lập trình viên (Developers / DevOps Engineers):** Những người thường xuyên có nhu cầu khởi tạo môi trường thử nghiệm, cấu hình máy chủ, cập nhật hàm serverless hoặc kiểm tra log hệ thống trong quy trình phát triển phần mềm. SatiBot giúp họ rút ngắn thời gian thao tác, tự động hóa các tác vụ lặp lại mà không cần phải chuyển đổi ngữ cảnh liên tục sang AWS Console.
- **Sinh viên ngành Công nghệ thông tin / Điện toán đám mây:** Nhóm người dùng đang trong quá trình học tập, thực hành các môn học về hạ tầng mạng và điện toán đám mây. Trợ lý cung cấp môi trường thực hành an toàn, hỗ trợ giải thích trực quan, đồng thời thiết lập các rào chắn kỹ thuật (guardrails) giúp sinh viên tránh việc cấu hình sai, mở cổng mạng nguy hiểm hoặc vô tình chọn các gói tài nguyên đắt tiền vượt gói Free Tier.

- **Quản trị viên và chủ doanh nghiệp (Tech Leads / Small Business Owners):** Những người có nhu cầu theo dõi tổng quan tình trạng tài nguyên, kiểm toán quyền truy cập (IAM Audit), rà soát nguy cơ bảo mật và kiểm soát chi phí hàng tháng (FinOps) thông qua ngôn ngữ tự nhiên mà không cần phải có kiến thức chuyên sâu về cú pháp dòng lệnh kỹ thuật.

1.3 Cách thức và quy trình người dùng sử dụng sản phẩm để đạt mục đích

Để đáp ứng toàn diện nhu cầu quản trị hạ tầng, SatiBot tập trung cung cấp giải pháp vận hành cho 04 dịch vụ nòng cốt của AWS: Amazon EC2, Amazon S3, AWS IAM và AWS Lambda. Dưới đây là chi tiết về mục đích và quy trình tương tác thực tế của người dùng đối với từng nhóm tính năng.

1.3.1 Nhóm kịch bản và quy trình quản trị Amazon EC2

Dịch vụ điện toán đám mây máy chủ ảo (Elastic Compute Cloud - EC2) là hạ tầng cốt lõi phục vụ việc chạy ứng dụng. SatiBot cung cấp 05 quy trình tương tác chính giúp người dùng quản lý vòng đời và bảo mật máy ảo một cách dễ dàng:

1. Khởi tạo máy chủ chuẩn hóa và xử lý trùng lặp tên:

- *Mục đích:* Tạo nhanh máy chủ để thử nghiệm hoặc triển khai website mà không phải cấu hình hàng loạt bước phức tạp, tránh tạo trùng tài nguyên.
- *Quy trình người dùng:*
 - Nhấn yêu cầu tạo máy kèm mục đích sử dụng (ví dụ: "Tạo cho tôi một máy chủ Ubuntu để chạy web demo, mở cổng SSH và HTTP").
 - Nếu tên máy đã tồn tại, xem thông báo từ trợ lý và chọn 1 trong 3 hướng giải quyết: dùng tiếp máy cũ, đổi sang tên mới, hoặc xóa máy cũ để tạo lại.
 - Nhận kết quả thành công gồm: Địa chỉ IP máy chủ, liên kết tải khóa đăng nhập an toàn (.pem) và câu lệnh kết nối mẫu.

2. Kiểm soát chi phí và xử lý vượt hạn mức tài nguyên (Cost Guardrails & Quota):

- *Mục đích:* Ngăn chặn việc vô tình chọn máy cấu hình quá đắt gây phát sinh hóa đơn lớn, đồng thời biết hướng xử lý khi tài khoản hết hạn mức tạo máy.
- *Quy trình người dùng:*
 - Nhấn yêu cầu loại máy mong muốn (ví dụ: "Tạo máy ảo c5.4xlarge 16 vCPU" hoặc "Tạo thêm 1 máy ảo Ubuntu").
 - Xem cảnh báo từ trợ lý:
 - * *Nếu yêu cầu máy cấu hình cao, đắt tiền:* Hệ thống phát cảnh báo chi phí hàng tháng ước tính vượt ngưỡng an toàn, tạm dừng lệnh và yêu cầu người dùng

nhập mã xác nhận chấp thuận rủi ro tài chính nếu thực sự bắt buộc dùng.

- * *Nếu tài khoản chạm giới hạn mức vCPU*: Trợ lý giải thích nguyên nhân bằng ngôn ngữ tự nhiên và tự động liệt kê danh sách các máy ảo đang chạy nằm trong hệ thống để người dùng cân nhắc.

- Nhấn lựa chọn xử lý: đồng ý chuyển về gói miễn phí, tắt bớt máy cũ không dùng, hoặc gửi yêu cầu nâng hạn mức.

3. Tra cứu và điều khiển vòng đời máy chủ (Bật / Tắt / Khởi động lại / Xóa):

- *Mục đích*: Giúp theo dõi toàn diện danh sách máy ảo và điều khiển trạng thái hoạt động mọi lúc mọi nơi để tối ưu ngân sách vận hành và tránh lãng phí tài nguyên.
- *Quy trình người dùng*:
 - Nhấn câu lệnh tra cứu hoặc điều khiển (ví dụ: "*Liệt kê các máy ảo đang chạy*", "*Tắt máy ảo web-demo*", "*Khởi động lại máy i-0abc123*", "*Xóa máy ảo staging*").
 - Xem bảng danh sách trực quan (ID, Tên, Trạng thái, IP, Thời gian chạy) hoặc thông báo trạng thái đã chuyển đổi thành công (nhận IP mới khi bật lại).
 - Với thao tác xóa vĩnh viễn: Xem cảnh báo rủi ro mất dữ liệu/tài nguyên bảo vệ và nhấn xác nhận lần cuối trước khi xóa.

4. Giám sát hiệu năng và phát hiện máy chủ lãng phí (FinOps & CloudWatch):

- *Mục đích*: Đo lường mức độ sử dụng tài nguyên để kịp thời dọn dẹp máy nhàn rỗi (tiết kiệm tiền) hoặc nâng cấp máy bị nghẽn tải.
- *Quy trình người dùng*:
 - Nhấn câu hỏi kiểm tra (ví dụ: "*Kiểm tra CPU máy i-0abc123 trong 24 giờ qua*").
 - Nhận số liệu đánh giá chi tiết:
 - * *Cảnh báo lãng phí*: Nhận cảnh báo lãng phí nếu máy chạy không tải kéo dài (kèm gợi ý tắt máy để tiết kiệm ngân sách).
 - * *Cảnh báo nghẽn tải*: Nhận cảnh báo quá tải nếu mức dùng chạm ngưỡng nguy hiểm (gợi ý nâng cấp gói).
 - Nhấn đồng ý theo khuyến nghị của trợ lý để trợ lý tự động xử lý.

5. Thiết lập tường lửa an toàn và hỗ trợ sự cố kết nối (SecOps):

- *Mục đích*: Bảo vệ máy chủ khỏi nguy cơ bị dò quét mật khẩu từ Internet (brute-force attack) và hỗ trợ chẩn đoán nhanh sự cố không thể kết nối SSH vào máy ảo.
- *Quy trình người dùng*:
 - Người dùng nhấn yêu cầu mở cổng hoặc hỏi nguyên nhân sự cố (ví dụ: "*Mở port 22 cho mọi người truy cập*" hoặc "*Tôi không SSH được vào máy ảo i-0abc123*,"

sao vậy? ”).

- *Phản hồi an ninh thông minh:* Trợ lý chủ động từ chối việc mở port 22 cho toàn bộ dải mạng công khai (0.0.0.0/0), giải thích nguy cơ bị tấn công mạng và đề xuất chỉ mở riêng cho địa chỉ IP hiện tại của chính người dùng.
- *Chẩn đoán kết nối:* Nếu phát hiện người dùng mất khóa private key, trợ lý chỉ rõ nguyên nhân và hướng dẫn sử dụng kênh quản trị an toàn thay thế (AWS Systems Manager Session Manager hoặc EC2 Instance Connect).
- Người dùng phản hồi đồng ý để áp dụng cấu hình an toàn được đề xuất.

1.3.2 Nhóm kịch bản và quy trình quản trị Amazon S3

Dịch vụ lưu trữ đối tượng (Simple Storage Service - S3) là nơi lưu trữ tập tin, bản sao lưu và dữ liệu tĩnh của hệ thống. SatiBot hỗ trợ 06 quy trình quản lý S3 an toàn và tối ưu:

1. Khởi tạo thùng chứa (S3 Bucket) an toàn và chuẩn hóa:

- *Mục đích:* Tạo kho lưu trữ đối tượng được thiết lập chế độ riêng tư theo mặc định và tuân thủ quy tắc đặt tên của AWS.
- *Quy trình người dùng:* Nhấn yêu cầu tạo kèm tên mong muốn (ví dụ: *”Tạo bucket tailieu-backup”*). Nếu tên bị trùng hoặc sai định dạng, xem hướng dẫn của trợ lý và nhấn lại tên mới. Nhận thông báo kho lưu trữ đã được tạo thành công ở chế độ bảo mật riêng tư.

2. Quét và khóa rủi ro lộ dữ liệu ra Internet (Security Scan & Remediation):

- *Mục đích:* Rà soát và ngăn chặn ngay lập tức nguy cơ rò rỉ dữ liệu quan trọng do vô tình mở quyền đọc/ghi công khai ra ngoài Internet.
- *Quy trình người dùng:* Nhấn yêu cầu kiểm tra (ví dụ: *”Kiểm tra xem có bucket nào đang bị lộ ra ngoài Internet không?”*). Hệ thống quét chính sách truy cập của toàn bộ các bucket trong tài khoản, trả về danh sách các thùng chứa đang có rủi ro. Người dùng chỉ cần nhấn lệnh xác nhận (ví dụ: *”Khóa lại giúp tôi”*) để trợ lý đóng quyền truy cập công khai tức thì.

3. Xóa thùng chứa an toàn có kiểm soát (chống xóa nhầm dữ liệu):

- *Mục đích:* Dọn dẹp kho lưu trữ cũ mà không lo ngại nguy cơ mất nhầm dữ liệu quan trọng đang lưu giữ bên trong.
- *Quy trình người dùng:* Người dùng nhấn yêu cầu xóa (ví dụ: *”Xóa bucket du-an-2025”*). Xem cảnh báo từ trợ lý về số lượng tập tin đang còn tồn đọng bên trong. Người dùng phải nhập xác nhận tường minh; khi đó hệ thống mới tiến hành dọn sạch các đối tượng và xóa bỏ bucket vĩnh viễn.

4. Tối ưu chi phí lưu trữ lâu dài (FinOps Lifecycle Rules):

- *Mục đích:* Giảm thiểu chi phí lưu trữ bằng cách tự động dịch chuyển các tập tin cũ, ít truy cập về các tầng lưu trữ giá rẻ hơn (S3 Standard-IA, S3 Glacier).
- *Quy trình người dùng:* Người dùng nhấn yêu cầu chuyển tầng lưu trữ kèm mốc thời gian (ví dụ: *"Tự chuyển file trong bucket sang kho lưu trữ giá rẻ sau 30 ngày"*). Hệ thống tự động thiết lập quy tắc vòng đời (Lifecycle Configuration Rule) trên S3 và gửi thông báo xác nhận chính sách tiết kiệm chi phí đã được áp dụng.

5. Chia sẻ tệp tin an toàn có thời hạn (Presigned URL):

- *Mục đích:* Cung cấp liên kết tải tệp tin an toàn cho đối tác bên ngoài trong khoảng thời gian xác định mà không cần cấp quyền truy cập tài khoản hay mở public kho dữ liệu.
- *Quy trình người dùng:* Người dùng nhấn tên tệp và thời hạn chia sẻ (ví dụ: *"Tạo link tải file hop-dong-2026.pdf trong 15 phút"*). Trọ lý sinh đường dẫn tải có chữ ký điện tử an toàn (Presigned URL) với thời gian tự hủy (TTL) chính xác là 15 phút và trả về liên kết trực tiếp trên khung chat.

6. Tra cứu dung lượng và tình trạng kho lưu trữ (Storage Analytics):

- *Mục đích:* Nắm bắt nhanh số lượng tệp tin, dung lượng sử dụng thực tế và dự toán chi phí lưu trữ của từng bucket.
- *Quy trình người dùng:* Người dùng đặt câu hỏi tra cứu (ví dụ: *"Bucket tailieu-duan có bao nhiêu file và chiếm bao nhiêu GB?"*). Hệ thống truy vấn CloudWatch Metrics và S3 API để thống kê chi tiết: số lượng objects, dung lượng tổng (GB), tầng lưu trữ và chi phí ước tính, hiển thị dưới dạng bảng rõ ràng.

1.3.3 Nhóm kịch bản và quy trình quản trị AWS IAM

Dịch vụ quản lý định danh và quyền truy cập (Identity and Access Management - IAM) là trung tâm kiểm soát an ninh của hạ tầng AWS. SatiBot cung cấp 05 quy trình quản trị IAM an toàn, tuân thủ nguyên tắc đặc quyền tối thiểu (Least Privilege):

1. Tra cứu vai trò (Role) và chính sách quyền hạn (Policy):

- *Mục đích:* Xem nhanh danh sách hoặc kiểm tra chi tiết các quyền hạn đang được gán cho nhân sự hoặc dịch vụ để phục vụ công tác kiểm toán an ninh.
- *Quy trình người dùng:* Người dùng nhấn câu hỏi tra cứu (ví dụ: *"Kiểm tra xem Role lambda-s3-role đang có những quyền gì?"* hoặc *"Liệt kê các Role dành cho dịch vụ EC2"*). Hệ thống phân tích tài liệu chính sách JSON và hiển thị bảng tóm tắt quyền hạn trực quan (tên quyền, dịch vụ được phép truy cập, phạm vi đọc/ghi) ngay trên khung chat.

2. Khởi tạo vai trò (Role) hoặc chính sách (Policy) mới theo nguyên tắc tối thiểu:

- *Mục đích:* Tạo mới đối tượng phân quyền cho máy chủ, ứng dụng hoặc nhân sự mà không phải tự tay viết các đoạn mã JSON chính sách phức tạp và dễ nhầm lẫn.
- *Quy trình người dùng:* Người dùng nhấn yêu cầu tạo kèm mục đích (ví dụ: *"Tạo một Role cho máy ảo EC2 chỉ được phép đọc dữ liệu từ S3"* hoặc *"Tạo Policy cho phép đọc log CloudWatch"*). Trợ lý tự động đề xuất cấu trúc quyền hạn chuẩn an toàn (chỉ cấp quyền đọc dữ liệu, không cấp thừa quyền ghi/xóa). Sau khi người dùng xác nhận, hệ thống gọi API tạo đối tượng và trả về ARN của Role/Policy.

3. Cấp hoặc điều chỉnh quyền truy cập:

- *Mục đích:* Bổ sung hoặc nói rộng quyền hạn cho nhân sự/dịch vụ khi phát sinh công việc mới trong dự án.
- *Quy trình người dùng:* Người dùng nhấn yêu cầu gán thêm quyền (ví dụ: *"Cấp thêm quyền đọc DynamoDB cho Role app-backend"*). Trợ lý đối soát đối tượng nhận quyền và chính sách tương ứng, yêu cầu người dùng xác nhận và trả về thông báo quyền truy cập mới đã được áp dụng thành công.

4. Thu hồi quyền truy cập (Least Privilege Enforcement):

- *Mục đích:* Tước bỏ các quyền hạn không còn sử dụng hoặc thu hồi các quyền nguy hiểm (như quyền AdministratorAccess cấp thừa cho tài khoản thực tập sinh) nhằm hạn chế rủi ro lộ lọt bảo mật.
- *Quy trình người dùng:* Người dùng nhấn yêu cầu gỡ bỏ quyền (ví dụ: *"Gỡ quyền AdministratorAccess khỏi tài khoản dev-intern"*). Hệ thống hiển thị thông báo phạm vi quyền chuẩn bị gỡ bỏ; sau khi người dùng xác nhận, hệ thống gỡ bỏ chính sách và thông báo tài khoản đã trở về mức phân quyền an toàn.

5. Xóa đối tượng IAM an toàn:

- *Mục đích:* Dọn dẹp dứt điểm các Role, Policy hoặc User cũ không còn sử dụng để tránh dư thừa tài nguyên và loại bỏ lỗ hổng bảo mật tiềm tàng.
- *Quy trình người dùng:* Người dùng gửi yêu cầu xóa (ví dụ: *"Xóa Role test-migration cũ giùm tôi"*). Trợ lý kiểm tra các quan hệ phụ thuộc (nếu Role đang được gán với máy ảo EC2 đang chạy, trợ lý sẽ cảnh báo nguy cơ làm dừng ứng dụng). Người dùng xác nhận lần cuối để trợ lý tự động tháo gỡ các liên kết an toàn trước khi xóa bỏ đối tượng IAM vĩnh viễn.

1.3.4 Nhóm kịch bản và quy trình quản trị AWS Lambda

Dịch vụ điện toán không máy chủ (AWS Lambda) cho phép chạy mã nguồn theo sự kiện. SatiBot hỗ trợ 05 quy trình quản trị và kiểm thử hàm serverless trực tiếp:

1. Tra cứu danh mục và kiểm tra cấu hình hàm (Inventory & Config Audit):

- *Mục đích:* Nắm bắt nhanh toàn bộ các hàm Lambda đang có trong tài khoản cùng các thông số vận hành cốt lõi (ngôn ngữ runtime, bộ nhớ RAM, thời gian timeout) phục vụ công tác kiểm toán tài nguyên.
- *Quy trình người dùng:* Người dùng gửi câu hỏi (ví dụ: *"Liệt kê các hàm Lambda trong tài khoản"* hoặc *"Hàm image-processor đang chạy ngôn ngữ gì và cấp bao nhiêu RAM?"*). Trợ lý hiển thị bảng tổng hợp trực quan gồm Tên hàm, Môi trường thực thi (Runtime), Dung lượng bộ nhớ (Memory) và Thời gian chờ tối đa (Timeout).

2. Chạy thử nghiệm hàm trực tiếp qua Chat (Direct Invocation):

- *Mục đích:* Kích hoạt và kiểm tra nhanh kết quả trả về của hàm với dữ liệu thử nghiệm ngay trên khung chat mà không cần đợi sự kiện bên ngoài hay cấu hình test event phức tạp trên Console.
- *Quy trình người dùng:* Người dùng nhấn lệnh chạy kèm dữ liệu đầu vào (ví dụ: *"Chạy thử hàm calculate-price với dữ liệu giá 100 và thuế 10"*). Hệ thống đóng gói dữ liệu, gọi API 'invoke', đo đạc thời gian thực thi và trả về kết quả đầu ra (Payload phản hồi, mã trạng thái HTTP 200, thời gian chạy tính bằng mili-giây) trực tiếp trên khung chat.

3. Tinh chỉnh tài nguyên nóng (Memory & Timeout Tuning):

- *Mục đích:* Nâng cấp cấu hình tức thời cho các hàm đang chạy chậm hoặc có nguy cơ sập do thiếu bộ nhớ hay hết thời gian chờ mà không phải can thiệp mã nguồn hay mở Console.
- *Quy trình người dùng:* Người dùng ra lệnh điều chỉnh thông số (ví dụ: *"Tăng thời gian timeout của hàm backup-data lên 30 giây"* hoặc *"Nâng RAM của hàm image-processor lên 512 MB"*). Trợ lý hiển thị bảng đối soát thông số cũ và thông số mới. Sau khi người dùng xác nhận, hệ thống gọi API cập nhật cấu hình và thông báo thành công.

4. Cấp phát nhanh liên kết HTTP công khai (Function URL Generation):

- *Mục đích:* Tạo nhanh một đường dẫn Endpoint HTTPS công khai (Function URL) để người dùng hoặc webhook bên ngoài có thể gọi trực tiếp hàm Lambda mà không mất công dựng và cấu hình API Gateway phức tạp.
- *Quy trình người dùng:* Người dùng nhấn: *"Tạo link Function URL công khai cho hàm image-api"*. Trợ lý tự động cấu hình Function URL, thiết lập quyền truy cập và gửi lại đường link HTTPS dạng `https://<url-id>.lambda-url.<region>.on.aws/` trực tiếp trên khung chat. Người dùng chỉ cần nhấp chuột vào liên kết trên trình duyệt là có thể kiểm chứng ngay kết quả thực thi của hàm.

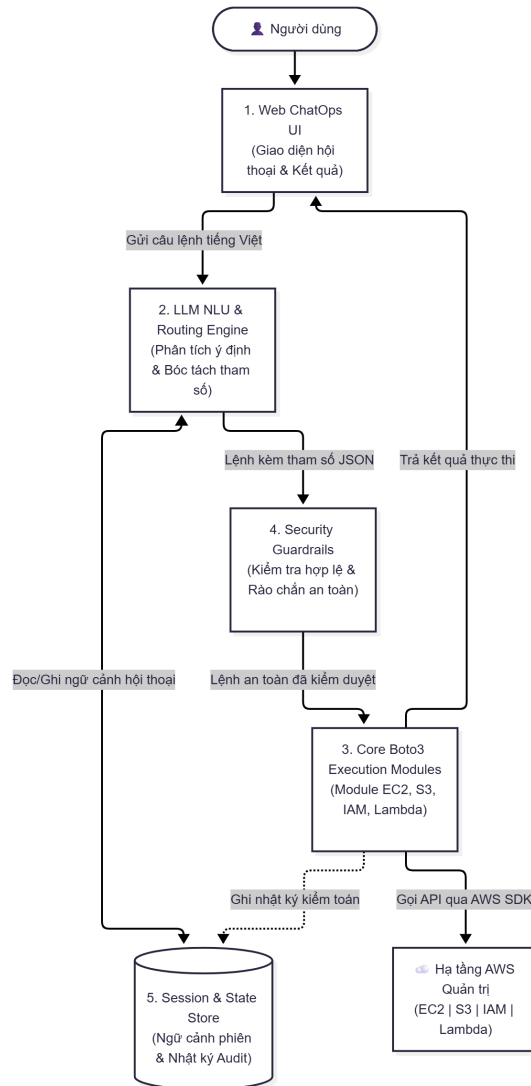
5. Dập cầu dao khẩn cấp để bảo trì hoặc ngắt lỗi (Emergency Kill-Switch):

- *Mục đích:* Vô hiệu hóa ngay lập tức một hàm đang bị lặp lỗi logic gây tiêu hao ngân sách hoặc cần ngắt kết nối gấp để bảo trì hệ thống mà không cần xóa bỏ mã nguồn của hàm.
- *Quy trình người dùng:* Người dùng nhấn lệnh ngắt khẩn cấp (ví dụ: "*Khóa tạm thời hàm order-service để bảo trì hệ thống*"). Trợ lý phát cảnh báo về việc hàm sẽ từ chối mọi yêu cầu mới (trả về lỗi throttling 429) và đề nghị người dùng xác nhận. Sau khi nhận xác nhận, hệ thống đặt mức thực thi đồng thời về 0 (Reserved Concurrency = 0), đưa hàm vào trạng thái tạm ngừng hoạt động an toàn. Người dùng có thể ra lệnh mở lại mức concurrency bất cứ lúc nào.

2. GIẢI PHÁP THỰC HIỆN DỰ KIẾN

2.1 Kiến trúc tính năng của hệ thống

Kiến trúc tính năng của hệ thống SatiBot được phân rã thành 05 khối phân hệ nghiệp vụ chính, bảo đảm tính mạch lạc, độc lập và khả năng mở rộng. Sơ đồ kiến trúc tính năng và luồng xử lý nghiệp vụ tổng thể được trình bày trong Hình 1.



Hình 1. Sơ đồ kiến trúc tính năng và luồng xử lý nghiệp vụ của SatiBot

Dựa trên sơ đồ kiến trúc tính năng (Hình 1), các phân hệ chức năng cốt lõi của hệ thống được giải thích chi tiết như sau:

- 1. Phân hệ Giao diện trò chuyện và Tiếp nhận yêu cầu (Web ChatOps UI):** Đóng vai trò là điểm chạm duy nhất của người dùng với hệ thống. Giao diện cung cấp khung hội thoại thời gian thực, cho phép người dùng nhập câu lệnh yêu cầu bằng ngôn ngữ tự nhiên (ưu tiên tiếng Việt), hiển thị bảng dữ liệu định dạng chuẩn, cung cấp các liên kết bảo mật có thời hạn (Presigned URL / Function URL), các nút bấm xác nhận tác

vụ nhạy cảm và biểu đồ/số liệu giám sát tài nguyên.

2. **Phân hệ Xử lý Ngôn ngữ Tự nhiên & Định tuyến Tác vụ (LLM NLU & Routing Engine):** Tiếp nhận các chuỗi hội thoại tiếng Việt từ người dùng, làm giàu ngữ cảnh (context enrichment) bằng lịch sử trò chuyện gần nhất, sau đó gửi tới mô hình ngôn ngữ lớn (LLM). Tận dụng cơ chế *Function Calling*, phân hệ này phân tích cú pháp, trích xuất chính xác tên hành động (action/tool) và các tham số kỹ thuật tương ứng dưới dạng dữ liệu JSON chuẩn hóa (ví dụ: tên máy ảo, loại instance, thời hạn presigned URL, dung lượng RAM...).
3. **Phân hệ Thực thi AWS SDK & Quản trị Dịch vụ (Core Boto3 Execution Modules):** Tập hợp các module chuyên trách độc lập viết bằng Python sử dụng thư viện AWS SDK (Boto3) để tương tác trực tiếp với các AWS API:
 - *Module EC2:* Quản lý máy chủ ảo, điều khiển chu kỳ hoạt động (Bật / Tắt / Khởi động lại / Xóa), kiểm tra vCPU quota và giám sát hiệu năng qua CloudWatch.
 - *Module S3:* Quản trị thùng chứa, rà soát và kích hoạt chặn truy cập công khai (Block Public Access), sinh liên kết tải có thời hạn (Presigned URL) và cấu hình quy tắc vòng đời lưu trữ (Lifecycle Rules).
 - *Module IAM:* Tra cứu vai trò và chính sách, sinh Role/Policy theo nguyên tắc đặc quyền tối thiểu (Least Privilege), cấp phát hoặc thu hồi quyền và xóa an toàn đối tượng IAM.
 - *Module Lambda:* Kiểm toán danh mục và cấu hình hàm, chạy thử nghiệm hàm trực tiếp qua Chat (Direct Invocation), tinh chỉnh cấu hình nóng (RAM & Timeout), cấp phát nhanh Function URL và cơ chế dập cầu dao khẩn cấp (Kill-Switch).
4. **Phân hệ An toàn, Xác thực & Rào chắn Bảo vệ (Security Guardrails):** Đóng vai trò là màng lọc bảo vệ hệ thống trước khi bất kỳ lệnh gọi API AWS nào được thực thi. Phân hệ này chịu trách nhiệm: (1) Kiểm tra tính hợp lệ và an toàn của tham số đầu vào; (2) Ngăn chặn các thao tác rủi ro cao (như mở cổng SSH 22 ra Internet 0.0.0.0/0, cấp quyền AdministratorAccess dư thừa); (3) Kích hoạt cơ chế xác nhận hai bước (two-step confirmation) đối với các thao tác phá hủy (xóa máy ảo, xóa bucket, thu hồi quyền); (4) Tính toán đối soát chi phí nhằm cảnh báo sớm việc vượt ngưỡng gói miễn phí (Free Tier).
5. **Phân hệ Quản lý Phiên & Lưu trữ Trạng thái (Session & State Store):** Duy trì ngữ cảnh hội thoại đa lượt (multi-turn conversation) của từng người dùng, lưu trữ trạng thái các tác vụ đang chờ xác nhận (pending confirmation state) và ghi lại toàn bộ nhật ký tương tác phục vụ mục đích kiểm toán (audit log) và giám sát hệ thống.

2.2 Kiến trúc triển khai của hệ thống

Kiến trúc triển khai của SatiBot được xây dựng hoàn toàn trên nền tảng Serverless của AWS nhằm đạt được tính sẵn sàng cao (High Availability), khả năng tự động mở rộng theo tải (Auto-scaling) và tối ưu hóa chi phí vận hành (chỉ trả phí cho thời gian thực thi thực tế).

Bảng 1 tổng hợp chi tiết các thành phần và dịch vụ được đề xuất sử dụng trong kiến trúc triển khai của hệ thống.

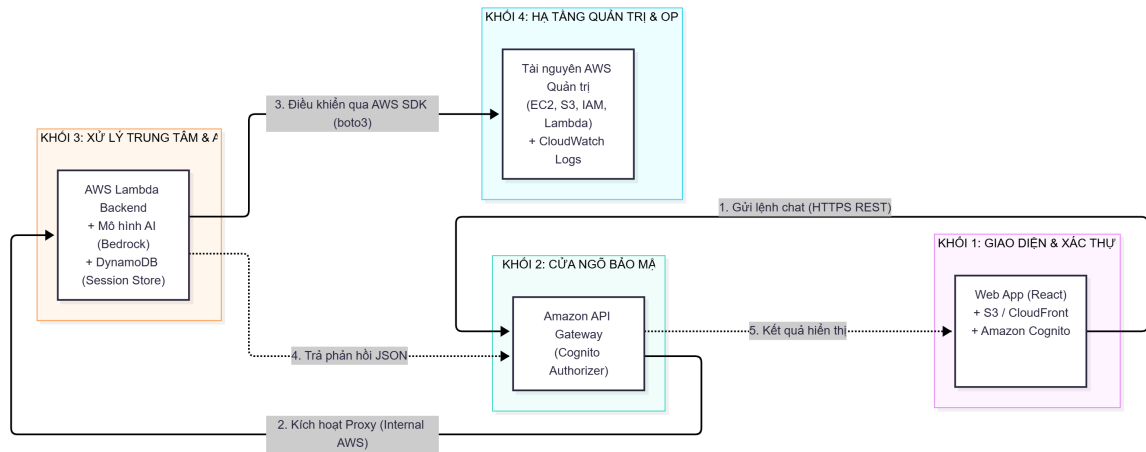
Bảng 1. Các thành phần và dịch vụ đề xuất trong kiến trúc hệ thống

Thành phần / Dịch vụ	Vai trò dự kiến
React	Xây dựng giao diện ứng dụng web (Frontend).
Amazon S3 & Amazon CloudFront	Lưu trữ static file và phân phối giao diện web đến người dùng với tốc độ cao, hỗ trợ bảo mật HTTPS.
Amazon Cognito	Quản lý xác thực, đăng ký và đăng nhập người dùng ứng dụng web, cấp phát JWT token.
Amazon API Gateway	Tiếp nhận và định tuyến các yêu cầu HTTP/HTTPS từ Frontend đến Backend, tích hợp xác thực token.
AWS Lambda	Chạy phần xử lý trung tâm (Backend serverless) của ứng dụng, tự động mở rộng quy mô.
Python / Boto3	Ngôn ngữ và thư viện AWS SDK được triển khai trong Lambda Backend để gọi các AWS API tương ứng.
LLM	Mô hình ngôn ngữ lớn phân tích ngữ cảnh yêu cầu của người dùng và hỗ trợ cơ chế <i>function calling</i> (chưa chốt nhà cung cấp hoặc mô hình cụ thể).
Amazon DynamoDB	Cơ sở dữ liệu NoSQL lưu trữ lịch sử hội thoại, các tham số và trạng thái tác vụ.
Amazon CloudWatch	Ghi log hệ thống và theo dõi hoạt động vận hành của các dịch vụ backend.
AWS IAM	Thiết lập, cấp phát và kiểm soát quyền truy cập giữa các thành phần trong hệ thống.

Kiến trúc triển khai của hệ thống được thiết kế theo mô hình phân tầng từ mức tổng quan đến các phân hệ chi tiết, làm rõ luồng dữ liệu và giao diện tương tác giữa các dịch vụ trên nền tảng AWS.

2.2.1 Sơ đồ kiến trúc triển khai tổng thể (Mức cao)

Sơ đồ Hình 2 mô tả bức tranh toàn cảnh kết nối giữa 04 khối thành phần chính của hệ thống SatiBot.



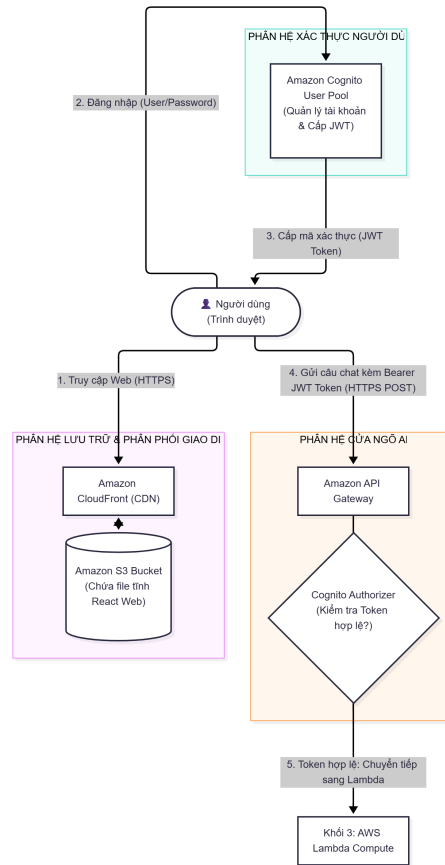
Hình 2. Sơ đồ kiến trúc triển khai tổng quan hệ thống SatiBot (Mức cao)

Kiến trúc tổng thể hoạt động qua 04 khối chức năng:

- **Khối 1 (Giao diện & Xác thực):** Người dùng tương tác với Web App (React) được phân phối qua S3/CloudFront và xác thực qua Amazon Cognito.
- **Khối 2 (Cửa ngõ bảo mật):** Amazon API Gateway tiếp nhận lệnh chat từ người dùng qua giao thức HTTPS REST và kiểm tra tính hợp lệ của JWT token thông qua Cognito Authorizer.
- **Khối 3 (Xử lý trung tâm & AI):** AWS Lambda tiếp nhận request qua cơ chế kích hoạt Proxy nội bộ của AWS, phối hợp cùng mô hình AI (Bedrock) và Amazon DynamoDB để phân tích ngữ cảnh, sinh lệnh kỹ thuật và trả phản hồi JSON.
- **Khối 4 (Hạ tầng quản trị & Ops):** Lambda điều khiển trực tiếp 04 dịch vụ AWS mục tiêu (EC2, S3, IAM, Lambda) thông qua AWS SDK (Boto3) và tự động đẩy nhật ký hoạt động sang Amazon CloudWatch Logs.

2.2.2 Chi tiết Phân hệ Giao diện, Xác thực và Cửa ngõ API (Khối 1 & 2)

Sơ đồ Hình 3 làm rõ chi tiết quy trình người dùng truy cập, đăng nhập và gửi lệnh vào cửa ngõ hệ thống.



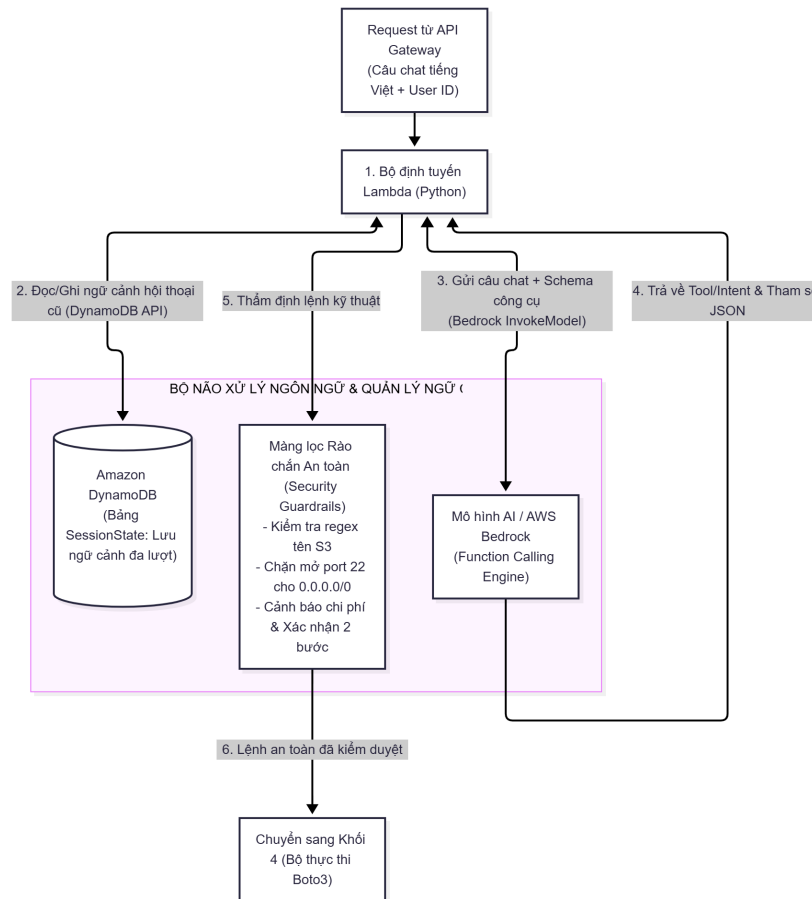
Hình 3. Sơ đồ chi tiết phân hệ Giao diện, Xác thực và Cửa ngõ API

Quy trình tương tác diễn ra tuần tự qua các bước:

- 1. Truy cập Web:** Người dùng truy cập website qua giao thức HTTPS; Amazon CloudFront tối ưu hóa tốc độ tải và lấy các tệp tĩnh (HTML, CSS, JS) từ Amazon S3 Bucket riêng tư.
- 2. Xác thực người dùng:** Người dùng nhập tài khoản (User/Password); Amazon Cognito User Pool thẩm định thông tin và cấp mã xác thực JWT Token (gồm ID Token và Access Token) về cho trình duyệt.
- 3. Gửi lệnh chat:** Người dùng nhập câu lệnh tiếng Việt; trình duyệt gửi HTTPS POST request đính kèm Bearer JWT Token vào tiêu đề (Authorization header) tới Amazon API Gateway.
- 4. Kiểm tra bảo mật tại cổng:** Cognito Authorizer tích hợp tại API Gateway giải mã và kiểm tra chữ ký số của token. Nếu token không hợp lệ, yêu cầu bị chặn ngay lập tức (trả về mã 401). Nếu hợp lệ, API Gateway kích hoạt chuyển tiếp yêu cầu sang Khối 3 (AWS Lambda Compute).

2.2.3 Chi tiết Phân hệ Xử lý Trung tâm và Trí tuệ Nhân tạo (Khối 3)

Sơ đồ Hình 4 mô tả luồng điều phối thông minh, làm giàu ngữ cảnh và cơ chế rào chắn an toàn bên trong hàm AWS Lambda.



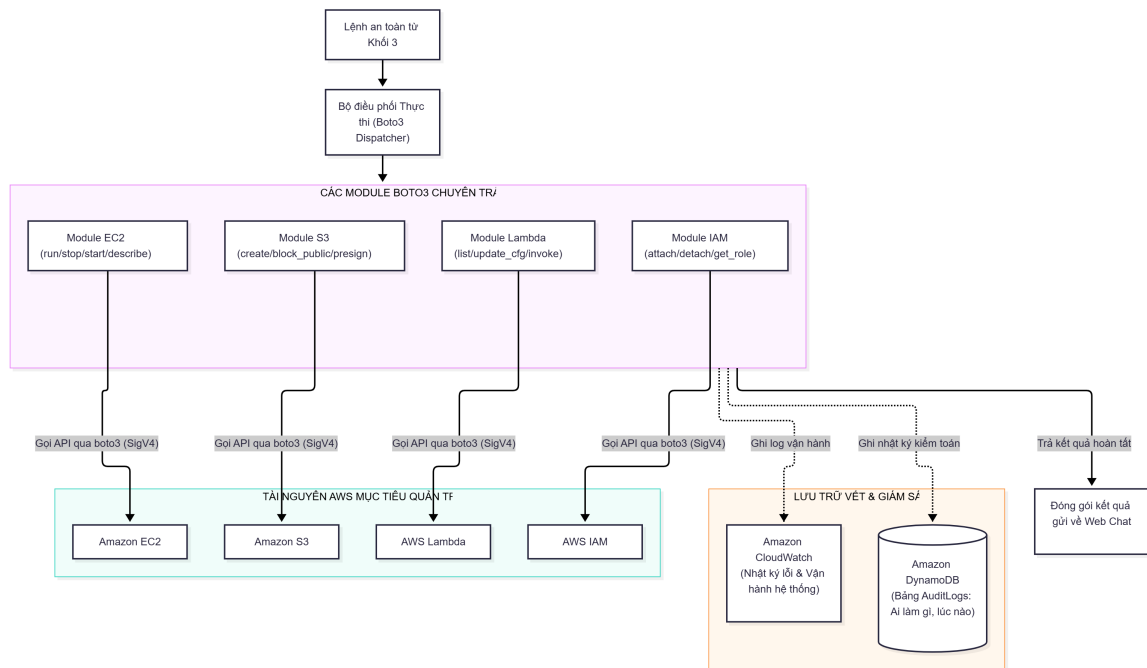
Hình 4. Sơ đồ chi tiết phân hệ Xử lý Trung tâm và Trí tuệ Nhân tạo

Các bước xử lý logic trung tâm bao gồm:

1. **Tiếp nhận yêu cầu:** Bộ định tuyến Lambda (Python) tiếp nhận payload từ API Gateway gồm câu chat tiếng Việt và định danh người dùng (User ID).
2. **Làm giàu ngữ cảnh:** Lambda gọi API DynamoDB để đọc/ghi lịch sử hội thoại gần nhất từ bảng SessionState, đảm bảo hệ thống hiểu được ngữ cảnh hội thoại đa lượt.
3. **Suy luận và trích xuất tham số (AI Bedrock):** Lambda gửi câu chat cùng bộ đặc tả công cụ (Tool Schema) tới mô hình AI trên AWS Bedrock qua API InvokeModel. Tận dụng cơ chế *Function Calling*, mô hình AI trả về cấu trúc JSON chứa tên công cụ (Tool/Intent) và các tham số kỹ thuật bóc tách được.
4. **Kiểm duyệt qua Rào chắn An toàn (Security Guardrails):** Trước khi thực thi, câu lệnh kỹ thuật bắt buộc phải đi qua màng lọc kiểm duyệt an toàn: (1) Kiểm tra biểu thức chính quy (regex) đặt tên bucket S3 hợp lệ; (2) Chặn tuyệt đối hành vi mở cổng SSH 22 ra dải IP toàn cầu 0.0.0.0/0; (3) Tính toán chi phí dự kiến và kích hoạt quy trình xác nhận hai bước đối với các lệnh nhạy cảm (xóa tài nguyên, cấp quyền cao). Khi đáp ứng toàn bộ tiêu chí an toàn, lệnh mới được bàn giao sang Khối 4 để thực thi.

2.2.4 Chi tiết Phân hệ Điều phối Boto3, Quản trị Tài nguyên và Giám sát (Khối 4)

Sơ đồ Hình 5 thể hiện cấu trúc các module thực thi mã nguồn Boto3, sự tương tác với các tài nguyên AWS đích và cơ chế lưu trữ vết giám sát.



Hình 5. Sơ đồ chi tiết phân hệ Điều phối Boto3, Quản trị Tài nguyên và Giám sát

Cơ chế vận hành của phân hệ quản trị và giám sát:

- Điều phối thực thi (Boto3 Dispatcher):** Nhận lệnh an toàn từ Khối 3 và chuyển giao chính xác cho module Boto3 chuyên trách:
 - Module EC2:* Quản lý máy ảo (run_instances, stop, start, describe).
 - Module S3:* Quản lý thùng chứa (create_bucket, block_public, presign).
 - Module Lambda:* Quản lý hàm (list_functions, cấu hình config, gọi invoke).
 - Module IAM:* Quản lý quyền (attach_role_policy, detach, get_role).
- Xác thực và ủy quyền:** Toàn bộ các cuộc gọi API tới 04 dịch vụ AWS đích đều sử dụng chữ ký điện tử AWS SigV4 được cấp phát động thông qua IAM Execution Role của hàm Lambda, tuân thủ nguyên tắc đặc quyền tối thiểu (Least Privilege).
- Lưu vết kiểm toán và giám sát:**
 - Hệ thống tự động đẩy nhật ký vận hành và thông báo lỗi sang Amazon CloudWatch Logs để phục vụ giám sát và gỡ lỗi.
 - Ghi nhận vết kiểm toán chi tiết (người dùng nào thực hiện, thao tác gì, tác động lên tài nguyên nào, vào thời điểm nào) vào bảng AuditLogs trên Amazon DynamoDB nhằm đảm bảo tính minh bạch và bảo mật.
- Đóng gói và phản hồi:** Sau khi hoàn tất thao tác trên AWS, kết quả thực thi được

định dạng chuẩn hóa và trả ngược về Web Chat dưới dạng bảng biểu hoặc thông báo trực quan cho người dùng.

3. KẾ HOẠCH TRIỂN KHAI VÀ ƯỚC TÍNH NỖ LỰC